

Dokümanın Adı:
BİLGİ GÜVENLİĞİ OLAY VE İHLAL YÖNETİMİ PROSEDÜRÜ

Gizlilik Derecesi: Tüm Kullanıcılar	Doküman No: BTD.PR03	İlk Yayın Tarihi 16.07.2018	Revizyon Tarihi 14.10.2020	Revizyon No: 2	Sayfa Sayısı: 1/6
--	---------------------------------------	--	---	---------------------------------	------------------------------------

REVİZYON TARİHÇESİ

Revizyon No	Revizyon Tarihi	Açıklama
2	14.10.2020	5.2.3, 5.3.1, 5.3.3, 5.3.4, 5.3.9 ve 5.5.1 maddelerinde Bilgi Teknolojileri Standardizasyon Müdürlüğü yerine Bilgi Güvenliği Operasyon Müdürlüğü yazıldı. 4.4, 4.5, ve 5.3.5 Bilgi Teknolojileri Standardizasyon Müdürlüğü yerine İş Sürekliliği Müdürlüğü yazıldı. 4.2 ve 4.3 maddeleri eklenmiştir. 4.2’de hangi durumlarda doldurulan İhlal olay formlarının kime gönderileceği ve sorumluluklar açıklanmıştır. 4.3’te çözümün gerçekleşeceği birimler açıklanmıştır. 4.6 Maddesinde İhlal olay istatistik bildirimi ve raporlanarak YGG de sunum sorumluları belirlenmiştir. 5.2.1. maddesindeki tabloda iletişim başlığının altındaki kutucuğa “EYS Yazılımı üzerinden form alınması, Bilgi Güvenliği Operasyon Müdürlüğü İletişim bilisimguvenligi@ptt.gov.tr, (0-312-2538685-86-87-88-89) İş Sürekliliği Müdürlüğü İletişim ism@ptt.gov.tr (0-312-5095040)” bilgileri girilmesi. 5.2.2 Maddesinde cümle düzeltildi. 5.2.3 Maddesinde Bilgi Teknolojileri Standardizasyon Müdürlüğü yerine Bilgi Güvenliği Operasyon Müdürlüğü yazıldı. 5.3.1 Maddesi düzenlendi. 5.3.2 Maddesi silindi 5.3.6 Maddesine Sözleşme Hükümleri eklendi. 5.3.8 Maddesine “SOME Yöneticisi bilgilendirilir. Birlikte olay incelenir. İnceleme sonucuna göre BT Başkanına rapor sunulur.” Cümleleri eklendi. Bu maddedeki “Basın açıklaması gereken durumlarda, Tanıtım ve Medya İlişkileri Daire Başkanlığına bilgi verilir.” Cümlesine “Hukuki süreç gerektiren durumlarda Hukuk Müşavirliğine gereğinin yapılması için yazı yazılır” cümlesi eklenerek yeni bir madde oluşturuldu. 5.3.10 Maddesi silindi. “personel kaynaklı mali zararlar ilgili bedel tespiti yapılarak PTT A.Ş Disiplin Amirleri ve Disiplin Kurullarına İlişkin Prosedüründe işlem yapılamayacağından” 5.3.11 “BT Başkan ve Müdürlerinin katıldığı haftalık BT toplantılarında İhlal Olaylar ile ilgili bilgilendirme ve değerlendirme yapılır.” Maddesi eklendi. 5.4 a,b,c,d,e,f madde işaretleri düzeltildi. 5.4.a ve 5.4.b maddeleri “form çıktı alınarak doldurulur” şeklinde düzeltildi. 5.4.c maddesi “BT Dairesi tarafından belirlenen” yerine “BT Dairesinin belirlediği” şeklinde düzeltildi. 5.4.e

Hazırlayan: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI	Süreç Sahibi: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	EYS Onayı ENTEGRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	Onaylayan / İdari GENEL MÜDÜR
---	--	--	---

Doküman No
BTD.PR03.2

14.10.2020

		maddesine “Adli” kelimesi ve “3. Taraf Bilgi Koruma Taahhütnamesi veya Sözleşme gereklerine” eklendi.
1	27.09.2019	4. maddedeki sorumluluklar düzenlendi. BT Standardizasyon Müdürlüğü görevleri BGOM olarak değiştirildi. Süreç ile Doküman uyumu sağlandı(5.3.8 ve 5.3.11) Referanslar ve Dokümandaki Disiplin Prosedürü ismi düzenlendi.
0	16.07.2018	

Hazırlayan: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI	Süreç Sahibi: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	EYS Onayı ENTEGRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	Onaylayan / İdari GENEL MÜDÜR
---	--	--	---

Doküman No
BTD.PR03.2

14.10.2020

1. AMAÇ

Bu prosedürün amacı Posta ve Telgraf Teşkilatı Anonim Şirketi bünyesinde yaşanabilecek bilgi güvenliği ihlal olaylarının ve bilgi güvenliği zayıflıklarının yönetimi ve ihlal olaylarının önlenmesi amacı ile ilgili usul ve esaslarla yetki ve sorumlulukları belirlemektir.

2. KAPSAM

Posta ve Telgraf Teşkilatı Anonim Şirketi'nde bilgi güvenliğini olumsuz etkileyebilecek tüm ihlal olayları ve bilgi güvenliği zayıflıklarının yönetimi ile ilgili usul ve esaslar dâhilinde Posta ve Telgraf Teşkilatı Anonim Şirketi'ndeki tüm birimleri ve çalışanları kapsar.

3. TANIMLAR VE KISALTMALAR

3.1 Amaç: Şirketin erişmeye çalıştığı uzun dönemli genel sonuçtur. Strateji oluşumuna temel teşkil eder ve planların gerçekleştirilmesinde yol göstericidir.

3.2 Bilgi Güvenliği İhlal Olayı: İş operasyonlarını ve itibarını tehlikeye atma ve bilgi güvenliğini tehdit etme olasılığı yüksek olan tek veya bir dizi istenmeyen ya da beklenmeyen bilgi güvenliği olayıdır.

3.3 Bilgi Güvenliği Riski: Belirlenmiş iş hedeflerinin başarısını olumlu/olumsuz etkileyen değişimdir.

3.4 Bilgi Güvenliği: Bu kapsamda yer alan bilginin gizliliği, bütünlüğü, kullanılabilirliği, doğruluğu, inkâr edilmeme ve güvenilirliği konularıdır.

3.5 Birim Üst Yöneticisi: Merkez teşkilatında Komite/Kurul Başkanını, Başkanı, 1. Hukuk Müşavirini, Daire Başkanını, Birim Sorumlusunu ve Özel Kalem Müdürünü; taşra teşkilatında ise Başmüdürü ifade eder.

3.6 Birim Yöneticisi: Merkez teşkilatında Şube/Teknik Müdürleri, taşra teşkilatında ise Teknik Müdürleri/Müdürleri(İhtisas) ve Merkez Müdürleridir.

3.7 Birim: Komite/Kurul, Başkanlık, Müşavirlik, Daire Başkanlığı, Birimler, Özel Kalem Müdürlüğü ve Başmüdürlükleri ifade eder.

3.8 BT: Bilgi Teknolojileri Daire Başkanlığıdır.

3.9 Düzeltici Faaliyet (DF): Saptanan bir uygunsuzluğun sebebini yok etmek için yapılan faaliyettir.

3.10 Entegre Yönetim Sistemi (EYS): Yönetimce PTT A.Ş.' de uygulanmakta olan; Kalite ve Müşteri Memnuniyeti, İş Sağlığı ve Güvenliği, Çevre, Bilgi Güvenliği Yönetim Sistemlerinin stratejik plan ile uyumlu olarak entegre edildiği yönetim sistemidir.

3.11 EYS Yazılımı: Şirket içerisinde yönetim sistemlerinin dokümantasyon ve işleyişinin yürütüldüğü yazılımdır.

3.12 Güvenli Bölge: Veri İşleme Merkezidir.

3.13 ISO 27001 (BGYS) Bilgi Güvenliği Yönetim Sistemi: PTT A.Ş. bünyesinde yer alan bilgi ve belgelerin korunması amacıyla bilgi güvenliğini kurmak, gerçekleştirmek, işletmek, izlemek, gözden geçirmek, sürdürmek ve geliştirmek için risk yaklaşımına dayalı tüm yönetim sisteminin bir parçası olup kurumsal yapı, politikalar, planlama faaliyetleri, sorumluluklar, uygulamalar, prosedürler ve kaynaklardır.

3.14 Merkez Müdürlükleri: Taşra teşkilatında Teknik Müdürlükler/Müdürlükler (İhtisas) dışında kalan müdürlüklerdir.

3.15 Merkez Teşkilatı: Şirketin Genel Müdürlük birimleridir.

3.16 Prosedür: Şirketi uygulamakta olduğu/uygulayacağı süreçleri etkileyen tüm aktivitelerle ilgili olarak sorumluları, iş akışlarını, bölümler arası ilişkileri belirleyen, kullanılacak formları ve talimatları açıklayan usul ve esaslardır. Prosedür, yürütülen faaliyetin amacı, kapsamı, sorumluları, uygulama alanı ve ilgili dokümanlar tanımlanarak hazırlanır. Prosedür; ne, nasıl, neden, nerede, ne zaman yapılacak, kim tarafından hangi yöntemle kontrol edilecek ve değerlendirilecek, nasıl kaydedilecek ve izlenecek sorularının yanıtlarını açık ve kısa olarak belirtir.

3.17 Şirket/PTT A.Ş. : Posta ve Telgraf Teşkilatı Anonim Şirketi'dir.

3.18 SOME: Siber Olaylara Müdahale Ekibidir.

3.19 Taşra Teşkilatı: Şirketin Genel Müdürlük birimleri dışındaki tüm birimleridir.

3.20 Teknik Müdürlükler/Müdürlükler(İhtisas): Merkez ve Taşra teşkilatında merkez müdürlükleri (PDM, PİM, KİM, merkez vb.) dışında kalan müdürlüklerdir.

3.21 Usom: Ulusal Siber Olaylara Müdahale Merkezidir.

3.22 Uygunsuzluk: Süreçte veya üründe şartların yerine getirilememiş olmasıdır. Majör ve Minör uygunsuzluk olarak ikiye ayrılır.

3.23 Yönetimin Gözden Geçirmesi(YGG): Üst Yönetim tarafından Şirketimizde uygulanmakta olan Entegre Yönetim Sistemi standartları gereği oluşturulan hedeflere ulaşmak amacıyla ele alınan konunun uygunluğunu, yeterliliğini, etkinliğini tayin etmek için yapılan faaliyettir.

4. SORUMLULUKLAR

4.1 Karşılaştıkları ve şahit oldukları ihlal olaylarını ihbar etmekten ve EYS Yazılımı üzerinde yayınlanmış **Bilgi Güvenliği Olay/İhlal Bildirim Formunu** doldurmaktan tüm çalışanlar sorumludur.

4.2 Sistem logları, Penetrasyon test sonuçları, hizmet aldığımız güvenlik platformları ve USOM'dan gelen bildirimler ile doldurulan **Bilgi Güvenliği Olay/İhlal Bildirim Formları** Bilgi Güvenliği Operasyon Müdürlüğü'ne, diğer doldurulan **Bilgi Güvenliği Olay/İhlal Bildirim Formlarının** tamamı İş Sürekliliği Müdürlüğü'ne iletilmelidir.

4.3 İhbara ilişkin çözüm rutin bir servis mahiyetinde ise ilk derece çözüm İş Sürekliliği Müdürlüğü tarafından gerçekleştirilir ancak rutin olmayan bir durum ise ilk derece çözümden Bilgi Güvenliği Operasyon Müdürlüğü sorumludur.

4.4 Bilgi Güvenliği Operasyon Müdürlüğü kendisine gelen ihbarları en kısa sürede değerlendirip çözmekten sorumludur. İş Sürekliliği Müdürlüğü ise kendisine gelen rutin olmayan ihbarları en kısa sürede değerlendirip, çözümü için ilgili birime sevk etmekle yükümlüdür.

4.5 İhbarların toplu halde değerlendirilmesi gerekiyorsa **Düzeltilici Faaliyet Prosedürüne** göre düzeltici faaliyet açılmasından İş Sürekliliği Müdürlüğü sorumludur.

4.6 Bilgi Teknolojileri Dairesi İş Sürekliliği Müdürlüğü, yıl içinde karşılaşılan Bilgi Güvenliği olay ve ihlaller ile ilgili raporları hazırlayarak sonuç istatistiklerini YGG öncesi EYS Daire Başkanlığına bildirmekten ve EYS Dairesi Başkanlığı ise bunları YGG toplantılarında raporlayarak sunulmasından sorumludur.

4.7 EYS Daire Başkanlığı, Bilgi Güvenliği Olay ve İhlallerle ilgili açılan düzeltici faaliyetlerin durumunu ve zamanında kapanıp kapanmadığını EYS Yazılımı üzerinden takip eder.

5. UYGULAMA

5.1 Genel Kural Ve Yöntemler

5.1.1 Olay halinde müdahaleyi ilgili/yetkili birim olarak Bilgi Güvenliği Operasyon Müdürlüğü yapar.

5.1.2 Güvenlik olay ve ihlallerine dair ihbarların, diğer Bilgi Teknolojileri süreçlerindeki talep ve problemlerde olduğu gibi birinci seviye talep birimi olarak Bilgi Güvenliği Operasyon Müdürlüğüne rapor edilmesi ve ihlale neden olan olayların ana sebeplerinin araştırılarak ihlallerin tekrar gerçekleşmemesi için gerekli önlemlerin alınması esastır.

5.1.3 Tüm güvenlik ihlalleri ve zayıflıklarının kayıt altına alınması gerekmektedir.

5.1.4 Bilgi sistemleri ve hizmetlerinin tüm çalışanları, yüklenicileri ve üçüncü taraf kullanıcılarını, sistemler ve hizmetlerdeki gözlenen veya şüphelenilen herhangi bir güvenlik zayıflığına dikkat etmeleri ve rapor etmeleri gerektiği konusunda bilgilendirilir

5.2 Bilgi Güvenliği İhlal Olayları Ve Zayıflıklarının Rapor Edilmesi

5.2.1 Olay halinde müdahaleyi ilgili/yetkili birim olarak Bilgi Güvenliği Operasyon Müdürlüğü yapar. İhlal Olayları ya da zayıflık tespit edildiğinde derhal EYS Yazılımında yayınlı form doldurularak Bilgi Güvenliği Operasyon Müdürlüğü yetkililerine haber verilir.

Olayın Tanımı	İlgili Birim	İletişim Bilgileri
Her türlü bilgi güvenliği ihlal ve olayları durumunda	EYS Yazılımı üzerinden form alınması Bilgi Güvenliği Operasyon Müdürlüğü İletişim bilisimguvenligi@ptt.gov.tr (0-312-2538685-86-87-88-89) İş Sürekliliği Müdürlüğü İletişim ism@ptt.gov.tr (0-312-5095040)	
Siber saldırılar, Web Saldırıları, Virüs, izinsiz giriş, trojan, spyware(casus yazılımları), DoS, DDoS vb.		
Tehdit ve Oltalama e-mailleri		
Veri kaybı, bilgilere yetkisiz erişim durumlarında		
Uygunsuz davranışlar ve politika, prosedür ve talimatlara uymayan kişiler için		
Ağ üzerinden Saldırıları		
Yetkisiz erişim ihlalleri		
Kontrolsüz Sistem Değişiklikleri		
Fiziksel ve Çevresel Güvenlik Denetim Hizmetleri İhlalleri		
Sistemi kesintiye uğratabilecek personel ihlalleri		

5.2.2 İhlalin ya da zayıflığın niteliğine göre ilgili Teknik Müdürlük, Bilgi Güvenliği Operasyon Müdürlüğü tarafından EYS Yazılımında yayınlı **Bilgi Güvenliği Olay/İhlal Formu**'nun en güncel halinin çıktısı alınıp doldurularak haberdar edilir. Olay veya ihlalin aciliyet durumuna göre yukarıda tanımlanan iletişim yöntemleri (e-posta, telefon) kullanılarak bildirim yapılabilir. Acil durumlarda iletişim kanalları kullanılarak yapılan bildirimlerin sonrasında, bildirimde bulunan personel tarafından **Bilgi Güvenliği Olay/İhlal Formu** doldurularak Bilgi Güvenliği Operasyon Müdürlüğüne bildirir.

5.2.3 Bilgi Güvenliği Operasyon Müdürlüğü; oluşan ihlal ya da zayıflığı bağlı olduğu üst yönetime, Makama/Makamlara ve İş Sürekliliği Müdürlüğü'ne bildirir.

5.3 Bilgi Güvenliği İhlal Olaylarının Değerlendirilmesi, İyileştirmelerin Planlanması ve Yönetilmesi

5.3.1 Bilgi Güvenliği Operasyon Müdürlüğü tarafından Bilgi güvenlik ihlalinin nedenleri araştırılır, gerekli durumlarda kullanıcı ve yöneticisi ile birlikte olay yerinde incelenir. Ayrıca; olayın net olarak hatırlanmasını sağlamak amacıyla ilgili kişilerin, olayla ilgili raporları alınır.

5.3.2 Meydana gelen bilgi güvenliği olayı veya bilgi güvenliği ihlal olayı Bilgi Güvenliği alt yapısı ve sistemini etkilemesi durumunda olaydan etkilenebilecek tüm birimlere Bilgi Güvenliği Operasyon Müdürlüğü tarafından bildirilir.

5.3.3 Farklı tipteki bilgi güvenliği ihlallerinin oluşmasını önlemek amacıyla ihlalin niteliğine uygun olarak alınacak önlemler, Bilgi Güvenliği Operasyon Müdürlüğü tarafından planlanır.

5.3.4 Bilgi Güvenliği İhlal Olay Formunda yapılan faaliyetler kaydedilerek form kapatılır ve aslı İş Sürekliliği Müdürlüğü tarafından arşivlenir.

5.3.5 Güvenlik ihlalini yapan hakkında yapılan işlemin niteliğine göre **PTT A.Ş Disiplin Amirleri ve Disiplin Kurullarına İlişkin Prosedürüne** göre işlem yapılır.

5.3.6 Bilgi güvenliği ihlalinin nedeni Tedarikçiden kaynaklanıyorsa, **Tedarikçi İlişkileri İçin Bilgi Güvenliği Politikası** doğrultusunda **Üçüncü Taraf Bilgi Koruma Taahhütnamesi ve Sözleşme** hükümlerine göre işlem başlatılır; müşteri nedenli ise, iş ve gizlilik sözleşmelerindeki hükümler uygulanır.

5.3.7 Güvenlik ihlallerinde, adli makamlara intikal etmesi gereken olaylar söz konusu ise olay yerindeki kanıtlar olayın gerçekleştiği Birimin Yöneticileri ve Bilgi Teknolojileri Operasyon Müdürlüğü tarafından muhafaza altına alınır. SOME Yöneticisi bilgilendirilir. Birlikte olay incelenir. İnceleme sonucuna göre BT Başkanına rapor sunulur.

5.3.8 Basın açıklaması gereken durumlarda, Tanıtım ve Medya İlişkileri Daire Başkanlığına bilgi verilir. Hukuki süreç gerektiren durumlarda Hukuk Müşavirliğine gereğinin yapılması için yazı yazılır.

5.3.9 Gerektiren durumlarda Usom’a, Bilgi Güvenliği Operasyon Müdürlüğü tarafından bilgi verilir.

5.3.10 BT Başkan ve Müdürlerinin katıldığı haftalık BT toplantılarında İhlal Olaylar ile ilgili bilgilendirme ve değerlendirme yapılır.

5.4 Taşrada Meydana Gelen Bilgi Güvenliği İhlal ve Olayların Bildirimi

Taşrada meydana gelen Bilgi Güvenliği Olay ve İhlallerin bildirimi aşağıdaki şekilde yapılır;

5.4.1 Bilgi Güvenliği İhlal ve Olayını tespit eden personel tarafından EYS Yazılımında yayımlı Bilgi Güvenliği Olay/İhlal Formu’nun güncel hali çıktı alınır, doldurularak birim yöneticisine bildirilir.

5.4.2 Birim yöneticisi tarafından İhlal/olay durumu değerlendirilir. İlgili birim tarafından müdahale edilecek olaylar için aksiyon başlatılır. Müdahale edilecek veya BT Dairesi tarafından müdahale edilmesi gereken ihlaller/olaylar EYS Yazılımında yayımlı Bilgi Güvenliği Olay/İhlal Formu güncel çıktısı doldurularak BT Dairesi Bilgi Güvenliği Operasyon Müdürlüğü’ne bildirilir.

5.4.3 İlgili birim tarafından veya BT Dairesinin belirlediği faaliyetlere göre EYS Yazılımı üzerinden Aksiyon Yönetimi Modülü kullanılarak aksiyon başlatılır.

5.4.4 Olay/İhlalin durumuna göre taşra tarafından alınması gereken önlemler birim yöneticisi tarafından gerçekleştirilerek sonuçları BT Dairesine raporlanır.

5.4.5 Değerlendirilen Bilgi Güvenliği İhlal ve Olayı cezai sorumluluk gerektiriyorsa birim üst yöneticisi tarafından adli mercilere başvurulması için Hukuk Müşavirliği’ne bilgi verilir.

5.4.6 Adli cezai sorumluluk gerektirmeyen durumlarda veya ihlal olayının niteliğine göre ihlal olayını gerçekleştiren personele/yükleniciye/üçüncü taraflara **PTT A.Ş Disiplin Amirleri ve Disiplin Kurullarına İlişkin Prosedürüne**, **3. Taraf Bilgi Koruma Taahhütnamesi** veya **Sözleşme** gereklerine göre işlem başlatılır.

5.5 İzleme ve Analiz

5.5.1 Bilgi Güvenliği Olay/İhlal Formları İş Sürekliliği Müdürlüğü tarafından 6 ayda bir analiz edilerek, ihlallerin ana konu başlıkları belirlenerek bu konularla ilgili alınması gereken köklü önlemler, eğitim programları tespit edilir. Analiz sonuçları EYS Daire Başkanlığı’na bildirilir. Gerekğinde **Düzeltilici Faaliyet Prosedürüne** göre EYS Yazılımı üzerinden Düzeltici Faaliyet başlatılır.

5.5.2 Bilgi güvenliği olaylarının değerlendirilmesi sonucunda edinilen bilgi ile edinilen tecrübe ve yeni kontrollerin oluşturulması, aynı olayın tekrar etmesini önleme veya yüksek etkili olayların oluşmasını engelleme maksatlıdır.

5.5.3 Oluşan Bilgi güvenliği olay/ihlal etkisine, yeni oluşan zafiyet ve tehditler için **EYS Risk ve Fırsatların Yönetimi Prosedürüne** göre risk değerlendirmesi yapılır.

5.5.4 Gerekli görülmesi durumunda olay ile ilgili kullanıcılara EBYS üzerinden bilgilendirme yapılır veya **Eğitim Prosedürüne** göre eğitimler planlanarak personelin bilgilendirmesi sağlanır.

6. YÜRÜRLÜK

Bu prosedür yayımlandığı tarihte yürürlüğe girer.

7. YÜRÜTME

Bu prosedürü Genel Müdür yürütür.

8. REFERANS DOKÜMANLAR:

BTD.FR05-Bilgi Güvenliği İhlal Olay Formu
EYS.FR22-Üçüncü Taraf Bilgi Koruma Taahhütnamesi
EYS.PK02-Tedarikçi İlişkileri İçin Bilgi Güvenliği Politikası
EYS.PR02-Düzeltici Faaliyet Prosedürü
EYS.PR20-EYS Risk ve Fırsatların Yönetimi Prosedürü